



Project Report

Project Name:

Implementing Snort as IPS IDS for Compliance Rules

Project Members:

Murtaza Ahmed (243648)

Abdul Haseeb Awan (243682)

Muhammad Taimoor Aslam (243881)

Iqra Nadeem (243704)

Rafia Naveed (243720)

Submitted to:

Professor Ahmed Naeem

❖ Tools used:

- 1) OpenSSH is the most widely used tool for managing remote systems securely, serving as the industry standard for encrypted communications.

➤ 5 Key Facts About OpenSSH and Port 22

- Secure Implementation:

OpenSSH is an open-source suite of tools (developed by the OpenBSD team) that uses the **SSH protocol** to encrypt all traffic, preventing eavesdropping and hijacking.

- Default Port:

By default, the OpenSSH server listens for incoming connection requests on **TCP port 22**.

- Core Functionality:

It allows users to log into remote servers via a command-line interface, execute commands, and transfer files securely using **SFTP** or **SCP**.

- Authentication Methods:

It supports highly secure authentication via **SSH key pairs** (asymmetric cryptography), which are much harder to crack than traditional passwords.

- Security Best Practice:

Because port 22 is a frequent target for "brute-force" attacks by bots, many administrators change the default port to a **non-standard number** (e.g., 2222) to reduce visibility.

2) Wire Shark tool:

Wireshark is the world's leading network protocol analyzer, used to capture and interactively browse the traffic running on a computer network. It provides a microscopic view of what is happening inside your network cables, making it essential for troubleshooting, security analysis, and protocol development.

3) Hydra: Brute-Forcing Port 22 (SSH), Port 23 (telnet).

- Targeting the Protocol:

Hydra identifies Port 22 as the default for SSH, but you can use the -s flag if the target is running SSH on a non-standard port.

- Credential Spraying:

You can target a single known user (e.g., -l root) or provide a list of potential usernames (e.g., -L users.txt) to find valid accounts.

- Dictionary Integration:

It is designed to ingest massive wordlists (like those created by **Crunch**) using the -P flag to test thousands of passwords per minute.

- The Power of Threading:

By using the -t flag (e.g., -t 4), you control how many parallel connections Hydra opens, balancing speed against the risk of crashing the service.

- Efficiency with -f:

The "finish" flag (-f) tells Hydra to stop immediately once the first valid set of credentials is found, saving time and resources.

4) Snort:

Snort is a tool that can be used to perform Intrusion Detections and intrusion prevention system.

It can be used to perform:

- **Packet Sniffing:**

Just like Wireshark, it can simply watch and display the live traffic on your screen so you can see what's happening in real-time.

- **Packet Logging:**

It can record the traffic into a file (log) on your Ubuntu machine. This is useful if you want to go back later and see exactly how the attack from Kali was performed.

- **Intrusion Detection (IDS):**

This is its most important job. It compares the traffic against a "Rulebook." If it sees a pattern that looks like an attack (like Hydra trying 100 passwords on Port 22), it immediately sends an **Alert**.

5) Nmap :

It is an essential open-source tool used for network discovery and security auditing. It works by sending raw IP packets to a target and analyzing the responses to determine which "hosts" are active on the network and what specific services (ports) they are running. In your lab, you would use it to scan your Ubuntu machine to confirm if **Port 22 (SSH)** or **Port 23 (Telnet)** are open and ready for an attack. Beyond just finding ports, Nmap can identify the exact version of the operating system and the software versions of the services running on those ports. It is considered the "gold standard" for footprinting

because its powerful Scripting Engine (NSE) can automatically detect vulnerabilities and security misconfigurations.

- Step By detection of Unauthorized activities again Compliance rules:
- Scanning Victim machine:

❖ Compliance Implemented:

1. PCI-DSS (Payment Card Industry Data Security Standard)

This is a mandatory security standard for any organization that handles, stores, or transmits credit card information. Its primary goal is to reduce credit card fraud.

- Target Organizations:

Banks (like HBL or Wells Fargo), Payment Processors (Visa, PayPal), and E-commerce platforms (Amazon, Daraz).

- What Rule (Port 23) is doing:

PCI-DSS Requirement 2.2.3 specifically mandates the use of secure protocols. Since **Telnet (Port 23)** sends data in cleartext, it is a direct violation. Snort rule ensures the organization is alerted if this insecure protocol is ever used.

- Implementing snort rule to detect telnet attempt:

```
alert tcp any any -> any 23 (msg:"PCI-DSS 2.2.3 VIOLATION: Telnet (Cleartext Protocol) Detected"; classtype:policy-violation; sid:3000001; rev:1;)
```

- Attempting telnet login:

- Command:

```
(kali㉿kali)-[~]  
$ telnet 192.168.100.128 23  
Trying 192.168.100.128 ...  
telnet: Unable to connect to remote host: Connection refused
```

- Alert On console:

```
Decoding Raw IP4
12/29-19:50:38.486729  [**] [1:3000001:1] PCI-DSS 2.2.3 VIOLATION: Telnet (Clear
text Protocol) Detected [**] [Classification: Potential Corporate Privacy Violat
ion] [Priority: 1] {TCP} 192.168.100.130:40074 -> 192.168.100.128:23
```

2. ISO/IEC 27001 (Information Security Management)

This is an international standard that provides a framework for managing sensitive company information so that it remains secure. It focuses heavily on "Access Control" and "Risk Management."

- **Target Organizations:**

Software Houses, IT Consultancies, Cloud Service Providers, and large corporations that manage global data.

- **What Rule (Port 22) is doing:**

Under ISO 27001 (Control A.9), organizations must control access to networks and services.

SSH Brute Force (Port 22) rule detects unauthorized attempts to guess passwords, which is a key requirement for proving that your access controls are working.

- **Installing ssh service on the Ubuntu:**

- ❖ **Command:**

```
ubuntu@ubuntu:~/Desktop$ sudo apt install openssh-server -y
```

- **Out-put:**

```
ubuntu@ubuntu:~/Desktop$ sudo apt install openssh-server -y
[sudo] password for ubuntu:
Reading package lists... Done
Building dependency tree... Done
Reading state information... Done
The following package was automatically installed and is no longer required:
```

➤ Start and enable ssh:

```
buntu@ubuntu:~/Desktop$ sudo systemctl enable ssh
Synchronizing state of ssh.service with SysV service script with /lib/systemd/s
systemd-sysv-install.
Executing: /lib/systemd/systemd-sysv-install enable ssh
buntu@ubuntu:~/Desktop$ sudo system start ssh
sudo: system: command not found
buntu@ubuntu:~/Desktop$ sudo systemctl start ssh
```

➤ Check ssh status:

➤ Command:

```
ubuntu@ubuntu:~/Desktop$ sudo systemctl status ssh
```

➤ Out-put:

```
buntu@ubuntu:~/Desktop$ sudo systemctl start ssh
buntu@ubuntu:~/Desktop$ sudo systemctl status ssh
● ssh.service - OpenBSD Secure Shell server
   Loaded: loaded (/lib/systemd/system/ssh.service; enabled; vendor preset: en
   Active: active (running) since Sat 2025-12-27 12:44:21 PKT; 3min 50s ago
     Docs: man:sshd(8)
           man:sshd_config(5)
   Main PID: 3469 (sshd)
      Tasks: 1 (limit: 5749)
     Memory: 1.7M
        CPU: 43ms
    CGroup: /system.slice/ssh.service
            └─3469 "sshd: /usr/sbin/sshd -D [listener] 0 of 10-100 startups"
```

➤ Recoinnance Using Nmap:

```

(kali㉿kali)-[~]
$ nmap 192.168.100.128
Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-29 18:33 PKT
Nmap scan report for 192.168.100.128
Host is up (0.050s latency).
Not shown: 999 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
MAC Address: 00:0C:29:B1:13:9A (VMware)

Nmap done: 1 IP address (1 host up) scanned in 1.57 seconds

```

➤ Setting Prevention rule to Implement PCI-DSS:

```

drop tcp any any -> any 22 (msg:"PCI-DSS: SSH Brute Force Detected (Hydra Suspe
< Suspected)"; flags:S; detection_filter:track by_src, count 4, seconds 60; cla
<0; classtype:attempted-admin; sid:2000001; rev:1;)

```

➤ Running Snort as IPS:

```

ubuntu@ubuntu-VMware:~/Desktop$ sudo snort -Q -c /etc/snort/snort.conf
Enabling inline operation
Running in IDS mode

--== Initializing Snort ==--
Initializing Output Plugins!
Initializing Preprocessors!
Initializing Plug-ins!
Loading rules file "/etc/snort/snort.conf"

```

➤ Starting Brute Force attacks using Hydra:

➤ Command:


```
(kali@kali)-[~]  
$ hydra -l ubuntu -P pass.txt ssh://192.168.100.128
```

➤ Performing Attack:

```
(kali@kali)-[~]  
$ hydra -l ubuntu -P pass.txt ssh://192.168.100.128  
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these ** ignore laws and ethics anyway).  
Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2025-12-29 18:58:23  
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks: use -t 4  
[WARNING] Restorefile (you have 10 seconds to abort... (use option -i to skip waiting)) from a previous session found, to prevent overwriting, ./hydra.restore  
[DATA] max 16 tasks per 1 server, overall 16 tasks, 10000 login tries (1:1/p:10000), ~625 tries per task  
[DATA] attacking ssh://192.168.100.128:22/  
[ERROR] all children were disabled due too many connection errors  
0 of 1 target completed, 0 valid password found  
[INFO] Writing restore file because 2 server scans could not be completed  
[ERROR] 1 target was disabled because of too many errors  
[ERROR] 1 targets did not complete  
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2025-12-29 18:58:49
```

The above attack has been blocked by snort running on the ubuntu machine as IPS.

➤ Snort alert log:

```
ubuntu@ubuntu-VNware:~/Desktop$ sudo tail -f /var/log/snort/alert  
12/29-19:27:53.128575 [Drop] [**] [1:2000001:1] PCI-DSS: SSH Brute Force Detected (Hydra Suspected) [**] [Classification: Attempted Administrator Privilege Gain]  
92.168.100.130:41132 -> 192.168.100.128:22  
12/29-19:27:53.130540 [Drop] [**] [1:2000001:1] PCI-DSS: SSH Brute Force Detected (Hydra Suspected) [**] [Classification: Attempted Administrator Privilege Gain]  
92.168.100.130:41130 -> 192.168.100.128:22  
12/29-19:27:53.274945 [Drop] [**] [1:2000001:1] PCI-DSS: SSH Brute Force Detected (Hydra Suspected) [**] [Classification: Attempted Administrator Privilege Gain]  
92.168.100.130:41134 -> 192.168.100.128:22  
12/29-19:27:53.322766 [Drop] [**] [1:2000001:1] PCI-DSS: SSH Brute Force Detected (Hydra Suspected) [**] [Classification: Attempted Administrator Privilege Gain]  
92.168.100.130:41150 -> 192.168.100.128:22  
12/29-19:27:53.366651 [Drop] [**] [1:2000001:1] PCI-DSS: SSH Brute Force Detected (Hydra Suspected) [**] [Classification: Attempted Administrator Privilege Gain]  
92.168.100.130:41160 -> 192.168.100.128:22  
12/29-19:27:53.411120 [Drop] [**] [1:2000001:1] PCI-DSS: SSH Brute Force Detected (Hydra Suspected) [**] [Classification: Attempted Administrator Privilege Gain]  
92.168.100.130:41174 -> 192.168.100.128:22  
12/29-19:27:53.455211 [Drop] [**] [1:2000001:1] PCI-DSS: SSH Brute Force Detected (Hydra Suspected) [**] [Classification: Attempted Administrator Privilege Gain]
```

3. HIPAA (Health Insurance Portability and Accountability Act)

HIPAA is a US-based law (widely adopted as a global standard) that protects patient medical records. It requires that Protected Health Information (PHI) is never leaked or accessed by unauthorized people.

- Target Organizations:

Hospitals, Health Insurance Companies, Medical Labs, and Pharmacies.

- What Rule (Outbound Connection) is doing:

HIPAA requires "Transmission Security" to prevent unauthorized data transfers. Your **Unauthorized Outbound Connection** rule flags whenever an internal server tries to send data to an unknown external IP, which is a common sign of a data breach or "Data Exfiltration."

➤ Adding snort rule for HIPAA:

```
drop ip $HOME_NET any -> $EXTERNAL_NET any (msg:"HIPAA VIOLATION: Unauthorized Outbound Connection Detected"; classtype:policy-violation; sid:4000001; rev:1)
```

➤ Output:

```
Decoding Raw IP4
12/29-20:17:52.444310 [Drop] [**] [1:4000100:1] HIPAA VIOLATION: Unauthorized Outbound Connection (Possible PHI Exfiltration) [**] [Classification: Potential Cor
on] [Priority: 1] (TCP) 192.168.100.2:53 -> 192.168.100.128:51816
12/29-20:17:52.448605 [Drop] [**] [1:4000100:1] HIPAA VIOLATION: Unauthorized Outbound Connection (Possible PHI Exfiltration) [**] [Classification: Potential Cor
on] [Priority: 1] (TCP) 192.168.100.2:53 -> 192.168.100.128:51832
12/29-20:17:58.909606 [Drop] [**] [1:4000100:1] HIPAA VIOLATION: Unauthorized Outbound Connection (Possible PHI Exfiltration) [**] [Classification: Potential Cor
on] [Priority: 1] (TCP) 192.168.100.2:53 -> 192.168.100.128:51816
12/29-20:17:58.911669 [Drop] [**] [1:4000100:1] HIPAA VIOLATION: Unauthorized Outbound Connection (Possible PHI Exfiltration) [**] [Classification: Potential Cor
on] [Priority: 1] (TCP) 192.168.100.2:53 -> 192.168.100.128:51832
```

4) NIST CSF – IPS Compliance (Port Scan Blocking)

➤ NIST CSF Function: Detect & Protect

❖ Objective:

Organizations must detect and prevent reconnaissance activities such as port scanning before an attacker can exploit vulnerabilities.

Real-World Scenario:

- An attacker performs a network scan using tools like nmap to discover open ports.
- The SOC/IPS system detects the scanning activity and blocks further scanning attempts.
- This prevents attackers from mapping the network and identifying potential targets.

➤ Setting Snort rule:

```
drop tcp any any -> any any (msg:"NIST CSF IPS: Port Scan Detected and Blocked"; classtype:attempted-recon; flags:S; detection_filter:track by_src, count 20, seconds 5; sid:8000001; rev:1)
```

❖ Attacker Machine:

```
(kali㉿kali)-[~]  
$ nmap -sS 192.168.100.128  
Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-29 20:49 PKT  
Nmap scan report for 192.168.100.128  
Host is up (0.021s latency).  
All 1000 scanned ports on 192.168.100.128 are in ignored states.  
Not shown: 1000 closed tcp ports (reset)  
MAC Address: 00:0C:29:B1:13:9A (VMware)  
  
Nmap done: 1 IP address (1 host up) scanned in 1.03 seconds
```

```
(kali㉿kali)-[~]  
$
```

❖ Output:

```
12/29-20:49:55.771167 [Drop] [**] [1:8000001:1] NIST CSF IPS: Port Scan Detected and Blocked [**] [Classification: Attempted Information Leak] [Priority:  
$ -> 192.168.100.128:6567  
12/29-20:49:55.771977 [Drop] [**] [1:8000001:1] NIST CSF IPS: Port Scan Detected and Blocked [**] [Classification: Attempted Information Leak] [Priority:  
$ -> 192.168.100.128:2041
```

```
IPS: Port Scan Detected and Blocked [**] [Classification: Attempted Information Leak] [Priority: 2] {TCP} 192.168.100.130:5590
```